JUNIOR TSHIKWEJ YAV

Analyste en Sécurité Applicative & Bug Bounty Hunter

Ariana, Tunisie | +216 52 540 684 | tshikwejj@gmail.com | Permis B
YesWeHack : @hxh | Intigriti : @hxh | GitHub : github.com/[à compléter] | LinkedIn : linkedin.com/in/[à compléter]

PROFIL PROFESSIONNEL

Étudiant en Master Cybersécurité, en recherche d'un stage de fin d'études en sécurité offensive / sécurité applicative. Double profil rare : développeur Full Stack (web et mobile) et chercheur en sécurité. Spécialisé dans la sécurité des applications web et des API — XSS, IDOR, injection REST/GraphQL, contournement d'authentification — ainsi que dans la recherche de vulnérabilités mémoire. Chasseur de bugs actif sur YesWeHack et Intigriti ; auteur d'un rapport Use-After-Free critique soumis au programme ARM (pilote GPU Mali). Combine la connaissance approfondie du développement et des compétences offensives pour identifier et divulguer responsablement des failles à fort impact.

COMPÉTENCES TECHNIQUES

- **Tests d'intrusion web :** OWASP Top 10, méthodologie de pentest applicatif
- **Vulnérabilités web :** XSS (DOM-based, Reflected, Stored), IDOR, SQLi, SSRF, CSRF
- **Sécurité des API :** REST, GraphQL, JWT, OAuth2, contournement RBAC, logique métier
- **Recherche de vulnérabilités :** CVE/CWE (CWE-79, CWE-89, CWE-200, CWE-416 Use-After-Free, CWE-362 Race Condition, CWE-639)
- **OSINT & reconnaissance :** Shodan, Amass, Google Dorks, Wayback Machine, scan de secrets GitHub
- **Outils offensifs :** Burp Suite, FFUF, Nuclei, Nmap, Postman
- **Développement :** ASP.NET Core, Node.js, Java, Flutter, SQL, HTML/CSS/JS
- **Systèmes & DevOps :** Linux, Nginx, durcissement VPS, Git, VSCode

RECHERCHE EN SÉCURITÉ & BUG BOUNTY

Programme ARM (via Intigriti) — Vulnérabilité mémoire critique

- Découverte d'une **race condition menant à un Use-After-Free** dans la fonction kbase_mem_evictable_make() (déclenchement via le OOM Shrinker) — pilote GPU **Mali Kbase (r49p1–r49p0)**.
- Rapport technique détaillé soumis avec preuve de concept (PoC) — ***en cours de triage*** (ni validé ni rejeté à ce jour).
- Classe de faille : CWE-416 (Use-After-Free) / CWE-362 (Race Condition) au niveau noyau Android.

YesWeHack (@hxh)

- Chasseur actif : injection sur API REST et GraphQL, contournement d'authentification, failles de logique métier.

Intigriti (@hxh)

- Recherche XSS (DOM-based et Reflected) dans des applications web ; reconnaissance OSINT et énumération.

EXPÉRIENCE PROFESSIONNELLE

Stagiaire Développeur Full Stack — Orientation Sécurité

Société Tunisienne de Banque (STB) — Tunis, Tunisie • Janvier 2025 – Juin 2025 (6 mois)

- Conception et développement d'une application web Full Stack de gestion des cartes bancaires.
- Mise en place d'une architecture backend sécurisée (Java, Node.js, SQL) : authentification JWT, rate limiting, validation stricte des entrées.
- Audit de sécurité de l'application : revue OWASP Top 10, tests XSS et SQLi sur tous les points d'accès API.
- Identification et correction de vulnérabilités IDOR dans les routes API de gestion des cartes.
- Rédaction d'une documentation de sécurité (SECURITY.md) et d'un modèle de menace.
- Tests, débogage et optimisation des performances avec validation sécuritaire à chaque couche.

PROJETS EN GÉNIE LOGICIEL

Plateforme de billetterie en ligne — mobile (iOS & Android) + web

- Plateforme complète de vente et de gestion de billets, déclinée en **application mobile cross-platform (Flutter — iOS et Android)** et en **application web Full Stack (ASP.NET Core, Node.js, SQL)**.

- Sécurité intégrée dès la conception (security by design) : **authentification JWT, gestion des rôles (RBAC), validation stricte des entrées, rate limiting** et protection contre les failles OWASP Top 10 (XSS, SQLi, CSRF).
- Fonctionnalités : gestion des événements et des utilisateurs, paiements sécurisés, génération et validation des billets.

Logiciel de conformité RGPD pour PME

- Outil d'évaluation de la conformité RGPD destiné aux PME, avec **quantification du risque en valeur financière ($)** pour prioriser les actions de remédiation.

Développement et déploiement de sites web

- Conception, développement (front et back) et mise en production de plusieurs sites web, avec hébergement et durcissement de serveurs VPS Linux/Nginx.

FORMATION

Master en Cybersécurité — Central University (2025 – 2027, en cours)
Licence en Génie Informatique et Systèmes — Central University (2024 – 2025)
Baccalauréat – Électricité Industrielle — Saint Vincent de Paul (2020 – 2021)

CERTIFICATIONS

- **OSCP – Offensive Security Certified Professional** *(en cours de préparation)*
- **Burp Suite Certified Practitioner (BSCP)** *(en cours de préparation)*

LANGUES

Français (courant) • **Anglais** (technique / professionnel)